

XSS 漏洞的事件触发机制（含绕过过滤核心技巧）

一、核心逻辑

当网站直接过滤<script>标签时,攻击者可通过“事件绑定”让恶意 JS 代码在特定行为下执行,常见触发场景包括用户点击、鼠标悬浮、页面加载、按回车等,这些均为触发 XSS 的“开关”。

二、高频触发事件分类

（一）鼠标事件（最易利用的用户交互触发）

鼠标操作作为网页交互基础,是 XSS 攻击的“高频选项”,常见事件如下:

1. onclick: 点击元素触发（如按钮、文字、图片）
2. 案例: 将恶意代码绑定到 onclick, 用户点击后执行（如“偷 Cookie”案例, 点击后弹出用户 Cookie, 实战中会发送至攻击者服务器）
3. onmouseover: 鼠标划过元素触发（无需点击, 隐蔽性更强）
4. 案例: 钓鱼页面将恶意代码绑定在导航栏文字, 鼠标划过即执行, 用户无察觉
5. 其他补充事件: oncontextmenu（右键触发）、onmousedown（鼠标按下触发）, 可在网站过滤 onclick 时作为绕过手段

（二）键盘事件（输入框 / 搜索框专属场景）

主要用于登录框、搜索框、留言框等输入交互区域（XSS 漏洞高发区）, 常见事件如下:

1. 核心事件: onkeydown
2. 触发场景: 按键按下时触发（如搜索框按回车）
3. 案例: 搜索框输入, 按回车后代码执行（真实搜索框 XSS 漏洞场景）
4. 补充事件: onkeyup（按键松开触发）、onkeypress（字符按键触发）, 实战中根据网站过滤规则选择使用

（三）HTML 事件（盲打 XSS 核心，无交互触发）

无需用户主动操作，页面 / 元素加载时自动触发，是“盲打 XSS”（攻击者看不到受害者页面仍能执行代码）的核心手段：

1. 王牌事件：onerror

- 触发场景：图片加载失败时触发
- 示例：`<img src=x onerror=alert(1)>`（src=x 必然加载失败，立即执行后续 JS）
- 优势：可去掉引号、不用闭合标签，能绕过 80% 的基础过滤，是 XSS 必学技巧

2. 核心事件：onload

- 触发场景：页面或元素加载完成后触发
- 示例：`<body onload=alert(document.cookie)>`，用户打开页面即自动执行，完全无感知，为盲打 XSS 常用方式

3. 补充事件：onsubmit（表单提交触发）、onchange（下拉框选择触发），适用于特定场景

三、实战绕过技巧

针对网站的过滤规则（如过滤 alert 关键字、过滤引号），可采用以下组合技巧：

1. 多事件组合：一个元素绑定多个事件（如同时绑定 onclick 和 onmouseover），无论用户点击或滑动，均能触发
2. 代码拼接：将关键字拆分拼接（如把 alert 拆为'ale'+ 'rt'），绕过关键字过滤
3. 无引号 / 无闭合：采用`<img src=x onerror=alert(1)>`这类无引号写法，可躲避过滤，是核心绕开方式

四、总结与实操建议

（一）核心结论

无论是鼠标、键盘还是 HTML 事件，本质都是 “寻找触发时机”，让浏览器执行恶意 JS 代码。掌握这些事件用法，可突破大部分网站的基础过滤，是后续挖掘反射型、存储型 XSS 漏洞的核心基础。

（二）实操测试建议

1. 动手测试页面上的每个示例
2. 修改代码验证效果（如将 alert 改为 prompt）
3. 观察触发结果，深入理解事件触发的核心逻辑